

Lectura 10: Introduction to Database Security

¿En qué consiste SQL Injection?

Existe un tipo de ataque llamado SQL injection que puede atacar a aplicaciones de bases de datos, las cuales deben tomar precauciones para estar protegidas. Este ataque se caracteriza porque desde la entrada del usuario desde un cliente a través de la interfaz de la aplicación puede diseñarse para aprovechar vulnerabilidades asociadas con la construcción dinámica de consultas SQL. Mediante la inyección SQL, un atacante puede insertar (o inyectar) código en una consulta que puede usarse para recuperar información a la que el atacante no está autorizado a ver, eliminar o modificar datos de forma maliciosa, o insertar datos que le otorguen acceso no autorizado a la base de datos. La inyección SQL se considera una de las principales preocupaciones de seguridad de software por el Proyecto de Seguridad de Aplicaciones Web Abiertas (OWASP) y por la lista de los 25 errores de software más peligrosos de la Enumeración de Debilidades Comunes (CWE)/SANS. La inyección SQL representa una amenaza para la confidencialidad, la integridad, la disponibilidad, la autenticación y la autorización.

¿En qué consiste Access Control?

En cualquier organización, deben definirse métodos de control de acceso para restringir el acceso a los recursos de la empresa, así como a los datos de empleados y clientes. El control de acceso es un componente fundamental para garantizar la confidencialidad y la integridad. Para proteger el sistema de información, el administrador de la base de datos es responsable de las siguientes tareas principales: instalar el sistema de gestión de bases de datos y configurarlo de forma segura; crear y proteger las cuentas de usuario y desarrollar controles de acceso adecuados; desarrollar y aplicar estándares para los programas de aplicación que acceden a la base de datos; cifrar los datos confidenciales; garantizar la seguridad de las conexiones de red a los datos; establecer mecanismos de auditoría adecuados para la base de datos; y proteger la base de datos contra intrusos mediante la identificación y mitigación de amenazas de seguridad, y la aplicación de controles y actualizaciones de seguridad según sea necesario.

- Un plan de control de acceso debe comenzar con medidas de seguridad física para el edificio, con precauciones especiales para las instalaciones informáticas.
- El desarrollo del control de acceso a los sistemas de información es un proceso que comprende autorización, identificación, autenticación y rendición de cuentas.

- El control de acceso a las bases de datos es el proceso que garantiza que el acceso a los datos u otros recursos se realice únicamente de forma autorizada.
- Las vistas electrónicas (e-views) son un método ampliamente utilizado para implementar el control de acceso en aplicaciones de bases de datos.

Comente el rol de la Observabilidad en la seguridad de bases de datos

La observabilidad es importante debido a que se pueden identificar momentos en que la base de datos actúe diferente a como debería estar comportando. Una herramienta de seguridad importante es el registro de seguridad, un libro de registro que documenta todos los intentos de violación de seguridad. La violación puede simplemente registrarse en el libro de registro o generar una alerta inmediata para el operador del sistema o el administrador de la base de datos (DBA). El simple hecho de conocer la existencia del registro puede ser un elemento disuasorio. Si el DBA sospecha que los datos están siendo comprometidos sin que se generen entradas en el registro de seguridad, es posible configurar un registro de auditoría. Este sistema de auditoría registra todos los accesos a la base de datos, incluyendo información sobre el usuario que solicitó el acceso, la operación realizada, la estación de trabajo utilizada, la hora exacta, el dato, su valor anterior y su nuevo valor, si lo hubiera. El registro de auditoría puede, por lo tanto, descubrir el origen de operaciones sospechosas en la base de datos, incluso si las realizan usuarios autorizados, como empleados descontentos.

¿Cómo se encripta información en una base de datos?

Para evitar el acceso directo a los datos a través del sistema operativo o su robo, estos se pueden almacenar en la base de datos de forma cifrada. Solo el sistema de gestión de bases de datos (SGBD) puede descifrarlos, de modo que quien los obtenga por otros medios recibirá datos codificados. Cuando los usuarios autorizados acceden correctamente a la información, el SGBD la recupera y la decodifica automáticamente. El cifrado también debe utilizarse al transmitir datos a otros sitios, para que quienes intenten interceptar comunicaciones también reciban datos cifrados. El cifrado requiere un sistema de cifrado, que consta de los siguientes componentes: un algoritmo de cifrado, que toma el texto plano como entrada, realiza operaciones sobre él y produce el texto cifrado como salida; una clave de cifrado, que forma parte de la entrada del algoritmo de cifrado y se elige de un conjunto muy amplio de claves posibles; un algoritmo de descifrado, que opera sobre el texto cifrado como entrada y produce el texto plano como salida; y una clave de descifrado, que forma parte de la entrada del algoritmo de descifrado y se elige de un conjunto muy amplio de claves posibles.